

- The service provider purchases certain assets (e.g., computer equipment or foreclosed real estate) at book value (which exceeds market value) or purchases capital stock from the institution.
- The service provider offers cash bonuses to the institution upon completion of the conversion.
- The service provider offers up-front cash to the institution. The provider states that the institution acquires the right to future cost savings or profit enhancements that will accrue to the institution because of greater operational efficiencies. These improvements are usually without measurable benchmarks.
- The institution defers expenses for conversion costs or processing fees under the terms of the contract.
- Low installation and conversion costs in exchange for higher future systems support and maintenance costs.

These inducements may offer a short-term benefit to the institution. However, the provider usually recoups the costs by charging a premium for the processing services. These excessive fees may adversely affect an institution's financial condition over the long-term. Furthermore, institutions should account for such inducements in accordance with generally accepted accounting principles (GAAP) and regulatory reporting requirements.

Accordingly, when negotiating contracts, an institution should ensure the provider furnishes a level of service that meets the needs of the institution over the life of the contract. The institution must ensure it accounts for contracts in accordance with GAAP. Contracting for excessive servicing fees and/or failing to account properly for such transactions is an unsafe and unsound practice. In entering into service agreements, institutions must ensure accounting under such agreements reflects the substance of the transaction and not merely the form.

Ongoing Monitoring

Action Summary

Management should monitor service provider performance and potential changes in institution requirements throughout the life of the contract. Monitoring should encompass:

- Key service level agreements (SLAs) and contract provisions;
- Financial condition of the service provider;
- General control environment of the service provider through the receipt and

- review of audit reports and other internal control reviews; and
- Potential changes due to the external environment.

Financial institutions should have an oversight program to ensure service providers deliver the quantity and quality of services required by the contract. The monitoring program should target the key aspects of the contracting relationship with effective monitoring techniques. The program should monitor the service provider environment including its security controls, financial strength, and the impact of any external events. The resources to support this program will vary depending on the criticality and complexity of the system, process, or service being outsourced.

To increase monitoring effectiveness, management should periodically rank service provider relationships according to risk to determine which service providers require closer monitoring. Management should base the rankings on the residual risk of the relationship after analyzing the quantity of risk relative to the controls over those risks. Relationships with higher risk ratings should receive more frequent and stringent monitoring for due diligence, performance (financial and/or operational), and independent control validation reviews. Personnel responsible for provider oversight should have the necessary expertise to assess the risks and should maintain suitable documentation. Management should use the oversight documentation when renegotiating contracts as well as developing contingency planning requirements.

User groups are another mechanism financial institutions can use to monitor and influence their service provider. User groups can participate and influence service provider testing (i.e., security, disaster recovery, and systems) as well as promote client issues. Independent user groups can monitor and influence a service provider better than its individual clients. Collectively, the group will constitute a significant portion of the service provider's business.

Key Service Level Agreements and Contract Provisions

Management should include SLAs in its outsourcing contracts to specify and clarify performance expectations, as well as establish accountability. These SLAs formalize the performance criteria against which the quantity and quality of service should be measured. Management should closely monitor the service provider's compliance with key service level agreements. To ensure an effective oversight program, the institution should develop:

- A formal policy that defines the SLA program;
- An SLA monitoring process;

- A recourse process for non-performance;
- An escalation process;
- A dispute resolution process; and
- A termination process.

Financial Condition of Service Providers

Institutions should have on-going monitoring of the financial condition of their provider(s). To fulfill its fiduciary responsibility, an institution involved in an outsourcing arrangement should determine the financial viability of its provider(s) on an annual basis. However, if the financial condition of the provider is declining or unstable, more frequent financial reviews are warranted. Once the financial review is complete, management should report the results to the board of directors or to a designated committee. At a minimum, management's review should contain a careful analysis of the provider's annual financial statement. Institution management may also use other forms of information to determine a provider's condition, such as independent auditor reports. These reports may contain information that can be vital in determining a provider's financial condition. Managers also can use information provided by public media (trade magazines, newspapers, television, etc.).

If the institution becomes aware that the provider's financial condition is unstable or deteriorating, the institution should implement its contingency plan. Even if the provider remains in operation, its financial problems may jeopardize the quality of its service and possibly the integrity of the data in its possession. Institutions should consider a provider's failure to provide adequate financial data as a potential red flag that there may be serious financial stability issues.

Termination of services due to the bankruptcy of the service provider can have a devastating effect on a serviced institution's operations. There may not be sufficient advance notice of termination, an effective contingency plan, or adequate access to provider personnel. In such a situation, the serviced institution is put into the position of having to find an alternate processing site with little advance notice.

At this point, a serviced institution has several alternatives including:

- Paying off the servicer's creditor(s) and hiring outside specialists to operate the center;
- Obtaining required equipment and software for in-house processing; and
- Transferring data files to another provider.

Most options are costly and may cause harmful operating delays.

In some instances, the provider owns the programs and documentation required to process the institution's files. Unless the contract contains an escrow agreement for

source code, the program and documentation are unavailable to the institution. These programs are often the TSPs only significant assets. Therefore, a creditor of a bankrupt TSP, in an attempt to recover outstanding debts, might seek to attach those assets and further limit their availability to institutions. The bankruptcy court may provide remedies to the institution, but only after adjudicating substantive matters.

General Control Environment of the Service Provider

To oversee the risks associated with the use of external providers effectively, the institution should evaluate the adequacy of a provider's internal and security controls. Management should ensure the provider develops and adheres to appropriate policies, procedures, and standards. When conducting its evaluation, the institution should consider the results of internal audits conducted by institution staff or a user group, as well as external audits and control reviews conducted by qualified sources. The IT Handbook's "Audit Booklet" provides additional details on the various types of external audit engagements for third-party audits of a service provider.

The institution's review of the audit should include an assessment of the following factors in order to determine the adequacy of a service provider's internal and security controls:

- The practicality of the service provider having an internal auditor, and the auditor's level of training and experience;
- The service providers external auditors' training and background; and
- Internal IT audit techniques of the service provider.

Financial institutions should conduct a regular, comprehensive audit of their service provider relationships. The audit scope should include a review of controls and operating procedures that help protect the institution from losses due to irregularities and willful manipulations.

Third-party review reports generated on external providers typically identify certain internal control measures that client institutions are responsible for implementing in order for the provider's accounting systems to be effective. These client institution internal control measures are essential. Financial institution management and audit personnel should verify that the recommended institution internal controls are working effectively, and that the controls effectively complement the accounting system controls described in the provider's third-party review.

Because of the need for an effective internal control program, designated personnel should periodically perform "around-the-computer" audit techniques that:

- Develop data controls (proof totals, batch totals, document counts, number of accounts, and pre-numbered documents) at the institution before submission to the provider. The auditor should sample the controls periodically to ensure their accuracy.

- Include spot-checking reconciliation procedures to ensure output totals agree with input totals, less any rejects.
- Sample rejected, un-posted, holdover, and suspense items to determine why they did not process and how they are addressed (to assure they are properly corrected and reentered on a timely basis).
- Verify selected master file information (such as service charge codes), review exception reports, and crosscheck loan extensions and deposit account entries to source documents.
- Spot-check computer calculations, such as loan rebates, interest on deposits, late charges, service charges, and past-due loans.
- Trace transactions to final disposition to ensure there are adequate audit trails.
- Review source input to ensure sensitive master-file change requests have the required prior approval by appropriate staff or management.
- Visit the provider periodically to assess the status of controls.
- Review other provider audits.

In addition, "through-the-computer" audit techniques allow the auditor to use the computer to check processing steps. These techniques use audit software programs to test extensions and footings and to prepare direct verification statements. These audit software programs often can invoke statistical sampling routines in generating their audit confirmations. If a serviced institution has audit software, it should make arrangements with the provider to allow its use.

Regardless of whether the information processing is internal or outsourced, the financial institution's board of directors should ensure adequate audit coverage. If the institution has no technical audit expertise, the non-technical audit methods can provide minimum coverage. The institution should supplement the internal audit with comprehensive outside IT audits.

Potential Changes due to the External Environment

The contract between the institution and the service provider should be written to encompass the institution's requirements at the time the contract is formed. Over time, the institution's needs may change due to changes in regulation, the economic environment, competition, and other factors outside the contract. Although the contract should provide for flexibility to meet those changing needs, the institution should monitor for changes and update its contract accordingly.

Related Topics

Business Continuity Planning

Action Summary

Financial institutions should:

- Establish ongoing and effective business continuity and information security monitoring programs;
- Effectively manage multiple service provider relationships; and
- Assess, monitor, and effectively control cross-border risks when foreign service providers are used.

Each financial institution should have an effective business continuity plan as outlined in the IT Handbook's "Business Continuity Planning Booklet." The financial institution should also establish ongoing effective business continuity monitoring programs to ensure TSPs adequately control the risks, including information security aspects, associated with the technology services provided. The financial institution has responsibility not only for those portions of the business continuity program performed in-house, but for any portions of the plan developed by a service provider or otherwise outsourced. Financial institutions should consider TSP-related business continuity programs when developing internal plans and programs.

The outsourcing risk management program should identify, for Business Continuity Planning (BCP) purposes, the specific responsibilities of all parties, particularly in the areas of information security and business continuity planning. Financial institutions must also consider which of their critical financial services rely on TSP services, including key telecommunication and network service providers.

The institution should understand all relevant service provider business continuity requirements, incorporate those requirements within its own business continuity plan, and ensure the service provider tests its plan annually. Management should require the service provider to report all test plan results and to notify the institution after any business continuity plan modifications. The institution should integrate the provider's business continuity plan into its own plan, communicate functions to the appropriate personnel, and maintain and periodically review the combined plan.

Many financial institutions rely on outside data processing providers and any extended interruption or termination of service can disrupt normal operations. Termination of services should occur according to the terms of the service contract, but can result from unanticipated events.

If the provider complies with basic industry standards and maintains an effective business continuity plan, disruption of services should be minimal and the contract will remain intact. The business continuity plan should require the provider to maintain current data files and programs at an alternative site and arrange for processing at another location. At a minimum, these provisions should allow the provider to process the most important data applications. The institution's business continuity plan, which should complement the provider's plan, is an essential recovery tool when disruption occurs with minimal advance notice.

Events that can cause interruption in the availability of an institution's technology include natural disasters, accidents, software errors, hardware failure, utility outages, and social, political, and economic instability. Even with an outsourcing arrangement, the institution should ensure appropriate backup provisions have been established for their critical data and related processing functions. Effective backup procedures will allow the institution to continue processing applications in the event the data communication system fails. Numerous options are available for management to consider, such as using batch rather than real-time processing methods, operating PCs in an offline mode, capturing data at the controller if transmission lines are lost, or altering communication links through redundant data communication lines, backup modems, or rerouted circuits from the local telephone carrier. Institutions that perform data capture or other functions in-house, should address alternative sites or other means in their backup plan to recover or continue these functions.

Regardless of the method used, an institution should have a comprehensive backup plan with procedures that detail how to obtain and use personnel and equipment. Institutions should test backup capabilities periodically to ensure protection is available and employees are familiar with the plan.

With respect to monitoring and maintaining business continuity plans, institutions should:

- Regularly review the business continuity plans of the service provider or vendor to ensure any services considered "mission critical" for the financial institution could be restored within an acceptable timeframe.
- Review the service provider's program for contingency plan testing. For critical services, annual or more frequent tests of the contingency plan are required.
- Assess service provider/vendor interdependencies for mission critical services and applications.

Outsourcing the Business Continuity Function

In addition to ensuring that outsourced financial and technology services include appropriate business continuity plans; financial institutions that outsource all or a portion of their business continuity capability should consider the following factors.

- **Staffing**-The provider should have sufficient and knowledgeable staff available to provide appropriate onsite technical support to ensure timely resumption of operations at the recovery site.
- **Processing Time Availability**-The provider should allocate sufficient processing time, resources, and security controls to accommodate the potential for multiple clients. The institution should ensure it could process normal volumes of work within appropriate time requirements.
- **Access Rights**-The provider should disclose any access limitations. The provider should guarantee the institution's right to use the site in case of an emergency.

Alternatively, the institution should understand any priority arrangements. For example, some sites operate on a first-come, first-serve basis until the site is at full capacity, but others have pre-arranged priorities based on contractual agreements.

- **Hardware and Software**-The recovery site should have compatible hardware and software. The institution should monitor the compatibility of the site to handle its specific computer hardware and software requirements. To facilitate the monitoring, the provider should be required by contract to notify the institution of any changes in the hardware, software, and equipment at the recovery site.
- **Security Controls**-The institution should ensure it can maintain adequate physical and logical security controls at the recovery site.
- **Testing**-The service provider contract should address access to the recovery site for periodic testing. At a minimum, the institution needs sufficient access to perform at least one full-scale test of the recovery site annually, including verification of telecommunications capabilities. Similarly, the institution should ensure the service provider also performs periodic tests of its own BCP and submits test results to customer financial institutions.
- **Confidentiality of Data**-The institution should ensure the provider can maintain the confidentiality of its business and customer data. The service provider should maintain controls sufficient to ensure the security and confidentiality of the information assets consistent with the institution's information security program. Confidentiality of data is particularly important when multiple clients operate from the same recovery site. Institution management should establish whether the service provider has addressed these issues in its contract, particularly the provisions concerning the Interagency Guidelines Establishing Standards for Safeguarding Customer Information.^[5]
- **Telecommunications**-The institution should review telecommunications redundancy and capacity at the recovery site, including how communications from the institutions to the recovery site will be established. The service provider should take steps to ensure the recovery site will have adequate telecommunications services (both voice and data) for all of its clients.
- **Reciprocal Agreements**-Financial institutions contracting with another institution for a recovery site should consider the above issues of staffing, processing availability, access rights for recovery or testing, compatibility, security, capacity, etc. Both institutions should ensure they maintain sufficient capacity to meet recovery time objectives and minimum service levels in the event one institution needs to recover operations
- **Space**-The recovery site should have adequate space to accommodate the affected institution's recovery staff.
- **Printing Capacity / Capability**-The recovery site should maintain adequate printing capacity to meet the demand of the affected institution under acceptable levels of service.
- **Contacts**-Institution management should know the procedures for declaring a disaster including who has the authority to declare a disaster and initiate use of the recovery site. Also, the institution should maintain an updated list of contacts names and numbers for the recovery site provider and know the procedures for communicating with the provider.

Outsourced business continuity arrangements can be cost-effective for smaller institutions when compared to establishing and maintaining dedicated alternate recovery sites. Institutions should periodically conduct a thorough test of outsourced disaster recovery services (at least annually).

Information Security/Safeguarding

Information assets are valuable, and institutions should ensure these assets are adequately protected in outsourcing relationships. Financial institutions have a legal responsibility to ensure service providers take appropriate measures designed to meet the objectives of the information security guidelines, and comply with GLBA 501 (b). Those measures should result from the institution's security process and should be included or referenced in the contract between the institution and the service provider. Refer to the IT Handbook's "Information Security Booklet" for additional information on the information security process.

In choosing service providers, management should exercise appropriate due diligence to ensure the protection of both financial institution and customer assets. Before entering into outsourcing contracts, and throughout the life of the relationship, institutions should ensure the service provider's physical and data security standards meet or exceed standards required by the institution. Institutions should also implement adequate protections to ensure service providers and vendors are only given access to the information and systems that they need to perform their function. Management should restrict their access to financial institution systems, and appropriate access controls and monitoring should be in place between service provider's systems and the institution.

Multiple Service Provider Relationships

A multiple service provider relationship is an environment where two or more service providers collaborate to deliver an end-to-end solution to the financial institution.

An institution can select from two techniques to manage this relationship, but remains responsible for understanding and monitoring the control environment of all servicers that have access to the financial institution's systems, records, or resources. The first technique involves the use of a lead service provider to manage the institution's various technology providers. The second technique, which may present its own set of implementation challenges, involves the use of operational agreements between each of the service providers or stand-alone contracts. If the first technique is employed, management should ensure its primary service provider has a contractual obligation to notify the financial institution of any concerns (controls / performance) associated with any of its outsourced activities. Management should also ensure the service provider's control environment meets or exceeds the institution's expectations, including the control environment of organizations that the primary service provider utilizes.

Stand-alone contracts with each service provider require increased management of each provider. Contracting for a technology solution by using one lead provider may lessen the need for the institution to become directly involved if subcontractors fail to perform, but it does not diminish the responsibility for monitoring the internal and security controls of subcontractors through the primary service provider relationship. Because the institution has less control using the lead provider approach, management should require by contract that TSPs notify the institution of all subcontractor relationships.

Outsourcing to Foreign Service Providers

Some institutions develop outsourcing relationships with service providers located in foreign countries. These arrangements can provide cost, expertise, and other advantages to the institutions and should be subject to the same due diligence and assessment as domestic outsourcing relationships. In addition, foreign outsourcing relationships result in unique strategic, reputation, credit, liquidity, transactional, geographic, and compliance risks that institutions should identify, assess, prevent, and control. See Appendix C for additional detail.